

ARKCLOUD

État des lieux — Sprint 6

Sécurité cloud avancée

Rapport technique complet

07 septembre 2026

Sources : [docs/architecture-arkcloud.md](#) · [docs/threat-model-stride.md](#) · [docs/adr/](#) (repo ArkCloud) · [README.md](#) (repo ArkCloudInfra)

1 Résumé exécutif

Contexte

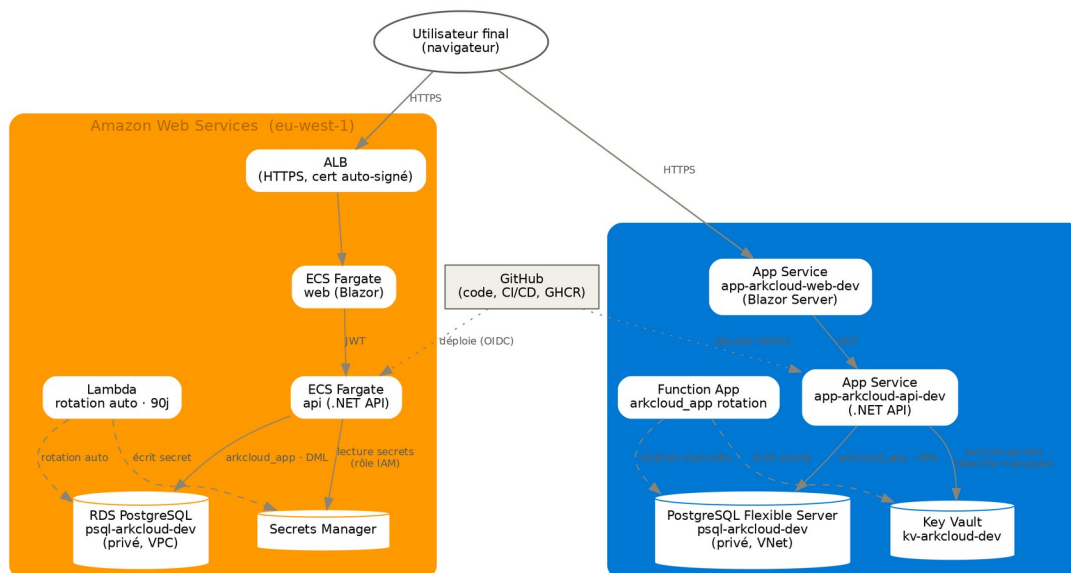
Le Sprint 6 (« Sécurité cloud avancée ») fait suite à un incident réel : la fuite publique d'un fichier tfplan contenant l'état Terraform complet, avec des secrets en clair (mots de passe admin PostgreSQL, clés de stockage, etc.). La remédiation immédiate — purge de l'historique git, rotation Tier 1 des secrets les plus critiques — a été suivie d'un travail de fond plus large.

Le travail de fond est structuré autour de quatre axes : durcissement de l'infrastructure (logs, chiffrement, IAM), modélisation de menaces STRIDE, réduction du privilège applicatif (rôle arkcloud_app), et vérification active de la restaurabilité plutôt que de la supposer.

État à date : les trois menaces STRIDE nouvellement identifiées ce sprint ont toutes une mitigation vérifiée ou une décision d'acceptation tracée en ADR. La rotation Tier 2 des secrets exposés dans la fuite est complète à l'exception d'un blocage confirmé côté Azure (clés Log Analytics, ticket support ouvert). La fenêtre de restauration PostgreSQL AWS est passée de moins de 24h à 6 jours, plafond réel du compte vérifié en direct plutôt que supposé.

2 Architecture — vue d'ensemble double-cloud

ArkCloud est déployé en double-cloud actif (Azure + AWS), deux piles applicatives complètes et indépendantes plutôt qu'un site principal et un site de secours passif. Chaque cloud héberge son propre frontend Blazor, sa propre API .NET, sa propre base PostgreSQL et ses propres secrets.



3 Modélisation de menaces STRIDE

Chaque flux de confiance (navigateur → ALB/App Service, Blazor → API, API → base, CI → cloud, rotation automatique → base) a été passé au filtre des 6 catégories STRIDE. Seules les catégories où une menace réelle a été identifiée sont détaillées ci-dessous.

3.1 Navigateur → ALB (AWS) / App Service (Azure)

Catégorie	Menace	Décision
Spoofing	Certificat auto-signé sur l'ALB AWS (pas de domaine réel disponible)	Acceptée — ADR-0003
Tampering	Modification du trafic en transit	Mitigée — HTTPS forcé des deux côtés
Repudiation	Aucun log d'accès ALB au niveau infra	Mitigée (Sprint 6) — bucket S3 dédié, vérifié de bout en bout
Denial of service	Aucun rate limiting au niveau infra	Acceptée pour l'instant — ADR-0008

3.2 Blazor → API

Catégorie	Menace	Décision
Spoofing	Falsification d'identité auprès de l'API	Mitigée — JWT Bearer
Tampering	Falsification du token/requête en transit	Mitigée — JWT signé HMAC + HTTPS
Information disclosure	CORS trop permissif	Mitigée — policy CORS nommée
Elevation of privilege	Accès au-delà du rôle utilisateur	Mitigée — politiques d'autorisation serveur

3.3 API → base (PostgreSQL)

Catégorie	Menace	Décision
Spoofing	Service usurpant l'API se connectant directement	Mitigée — réseau privé uniquement
Tampering	Interception/modification du trafic SQL	Mitigée — TLS forcé
Information disclosure	Donnée personnelle fuitant dans les logs applicatifs	À traiter — objet du chantier RGPD séparé
Elevation of privilege	Compte applicatif trop privilégié (arkcloudadmin)	Résolu (Sprint 6) — voir section 4

3.4 CI (GitHub Actions) → cloud

Catégorie	Menace	Décision
Spoofing	Workflow usurpé obtenant des identifiants cloud	Mitigée — OIDC, aucune clé

Catégorie	Menace	Décision
		statique
Elevation of privilege	Rôle CI plus permissif que nécessaire	Mitigée (Sprint 6) — AdministratorAccess retiré
Elevation of privilege	GHCR_PAT, secret humain dans le chemin de déploiement	Acceptée — ADR-0007
Repudiation	Modification d'infra sans traçabilité	Mitigée — PR + plan publié + gate manuel

3.5 Rotation automatique (Runbook/Lambda) → base

Catégorie	Menace	Décision
Elevation of privilege	Identité de rotation trop permissive	Mitigée (Sprint 6) — rôles personnalisés dédiés
Denial of service	Rotation ratée rendant la base inaccessible	Partiellement mitigée — alarme CloudWatch (AWS), pas d'équivalent Azure
Tampering	Restaurabilité après rotation jamais vérifiée	Résolu (Sprint 6) — drill réel, voir section 5

3.6 Bilan

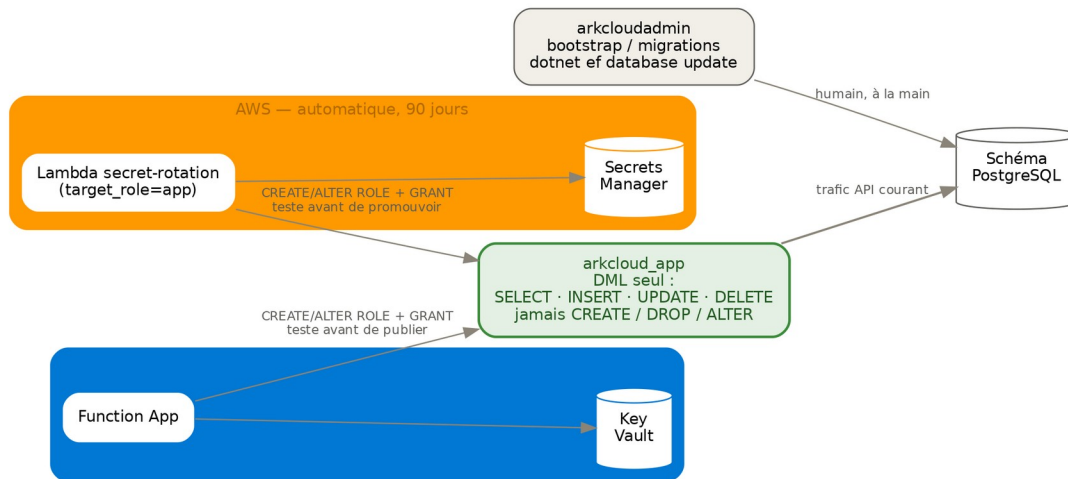
Zéro menace en attente

Aucune menace ne reste au statut « à traiter » parmi les trois candidates identifiées spécifiquement par cet exercice STRIDE ce sprint (logs ALB, privilège applicatif, restaurabilité post-rotation) — chacune a une mitigation vérifiée en conditions réelles, pas seulement documentée sur le papier.

- Résolues ce sprint : logs d'accès ALB (repudiation, flux 1), privilège applicatif (élévation, flux 3), restaurabilité post-rotation (tampering, flux 5).
- Acceptées et tracées en ADR : certificat auto-signé (ADR-0003), Jwt:Key non rotatable à chaud (ADR-0004), GHCR_PAT secret humain (ADR-0007), absence de rate limiting infra (ADR-0008).
- Hors périmètre STRIDE, tracé séparément : fuite de donnée personnelle dans les logs (chantier RGPD dédié).

4 Le rôle applicatif arkcloud_app

Jusqu'au Sprint 6, ArkCloud.API se connectait à PostgreSQL comme arkcloudadmin — le compte admin du serveur, avec bien plus de droits que nécessaire pour du CRUD applicatif. Le Sprint 6 bascule vers un rôle dédié, strictement DML (SELECT/INSERT/UPDATE/DELETE, jamais CREATE/DROP/ALTER), vérifié en conditions réelles sur les deux clouds.



Deux mécanismes de rotation différents, pas par choix esthétique mais parce que les deux Automation/rotation existants n'avaient pas le même point de départ :

	Azure	AWS
Mécanisme	Function App (Flex Consumption), déclenchement manuel	Lambda existante étendue (target_role=app), automatique 90j
Pourquoi différent	Le Runbook admin n'a aucun accès réseau au VNet — l'étendre demanderait un Hybrid Runbook Worker (VM continue, écarté pour coût/bénéfice)	La Lambda de rotation admin tourne déjà dans le VPC — extension sans nouvel accès réseau
État réel	Rôle créé et rotation vérifiée en conditions réelles (mot de passe testé avant publication)	Bascule confirmée : task definition ECS active, ALB répond 200 OK sur /health
Décision de référence	ADR-0010 (Kudu retenu à terme, implémentation en backlog — le Function App reste le mécanisme réel utilisé)	—

5 Drill de restauration — STRIDE flux 5

Exécuté en conditions réelles le 31/08/2026, pas comme un exercice théorique : snapshot manuel de psql-arkcloud-dev pris, rotation immédiate du secret admin déclenchée, snapshot restauré dans une instance jetable isolée (réseau privé, jamais exposée publiquement). Connexion effectuée depuis une instance EC2 temporaire via AWS Systems Manager (aucune clé SSH, aucune exposition).

- Résultat confirmé : la connexion avec le mot de passe actuel échoue sur l'instance restaurée (FATAL: password authentication failed) — la menace est réelle, pas hypothétique.
- Procédure de récupération testée et validée : récupération de l'ancien mot de passe via la version AWSPREVIOUS du secret, connexion réussie, puis ALTER ROLE pour resynchroniser sur le mot de passe courant.
- Toutes les ressources temporaires du drill détruites après coup — instance RDS, instance EC2, rôle IAM, security group, snapshot manuel — aucune trace persistante.
- Finding annexe : BackupRetentionPeriod de psql-arkcloud-dev à seulement 1 jour, insuffisant pour un PITR au-delà de 24h — traité séparément, voir section 6.

6 Rétention des backups RDS — plafond Free Tier confirmé

La rétention de 1 jour découverte pendant le drill n'était pas un oubli mais une contrainte AWS Free Tier déjà documentée dans le code (7 jours rejeté à la création avec `FreeTierRestrictionError`), dont le plafond exact n'avait jamais été mesuré. Testé en direct le 07/09/2026 via `ModifyDBInstance (apply_immediately)` plutôt que supposé :

Valeur testée	Résultat
3 jours	Accepté
6 jours	Accepté
7 jours	Refusé (<code>FreeTierRestrictionError</code> , confirmé dès la création initiale)

Résultat

`backup_retention_period` relevé à 6 dans `environments/dev/main.tf` — fenêtre de PITR passée de moins de 24h à 6 jours, sans changer de compte AWS ni de plan tarifaire.

7 Rotation des secrets — Tier 2

Après la rotation Tier 1 (mots de passe admin PostgreSQL, faite en urgence à la découverte de la fuite), le Sprint 6 a traité les secrets restants exposés dans le même `tfstate` :

Secret	Statut
Clés de compte de stockage Azure (flow logs, storage cost-guard)	Rotées — les deux comptes, les deux clés (primary/secondary)
Certificat auto-signé ALB (clé privée, certificat)	Roté via terraform taint + apply — zéro downtime vérifié (ARN ACM stable)
Clés Automation Account DSC (cost-guard)	Dépriorisées — usage effectivement nul, risque jugé négligeable
Clés partagées Log Analytics Workspace	Bloqué — Microsoft a retiré ces clés de l'UI et l'API REST documentée renvoie une erreur incohérente avec son propre contrat public ; 0 agent legacy connecté au workspace ; ticket support Azure ouvert

8 Registre des décisions d'architecture (ADR)

ADR	Titre	Statut
0003	Certificat auto-signé sur l'ALB AWS	Acceptée (temporaire)
0004	Rotation automatique sélective des secrets	Acceptée
0007	GHCR_PAT — risque accepté	Acceptée
0008	Rate limiting applicatif seul	Acceptée (temporaire)
0009	Stratégie de branches et versionning	Acceptée
0010	Bootstrap/rotation arkcloud_app Azure — Kudu manuel	Acceptée (backlog)
0011	Authentification passwordless arkcloud_app	Proposée

9 Ce qui reste ouvert

- Ticket support Azure — régénération des clés Log Analytics, en attente de réponse Microsoft.
- Procédure Kudu pour la rotation arkcloud_app côté Azure — en backlog, nécessite d'ajouter un serveur SSH au Dockerfile de l'API (jamais fait à ce jour).
- Authentification passwordless (ADR-0011) — design vérifié, implémentation candidate pour un sprint applicatif dédié (Sprint 7/8).
- Chantier RGPD — minimisation des logs applicatifs, item « à traiter » distinct de STRIDE.